



The *RMF Resources for New System Owners* Quick Start Guide is intended to inform organizational officials with system ownership responsibilities about existing NIST-provided RMF resources. Newly appointed system owners may have questions about and in preparation for taking on the role including:

- Where do I start?
- What do I need to know?
- What am I expected to do and what am I responsible for?

The scope of this guide is on the NIST-provided resources that may assist system owners in their initial preparation for the role. Although organized to address the above questions, it is not prescriptive in any way and is not a substitute for any organizational policy, procedures or guidance required for the role.

We begin by reviewing what the role of the system owner typically entails with regard to managing security and privacy risks per the NIST RMF methodology, noting that each organization establishes their own set of responsibilities and expectations for system owners:

In the context of the RMF*, the *System Owner* is typically responsible for:

- the procurement, development, integration, modification, operation, maintenance, and disposal of a system.
- addressing the operational interests of the user community and for ensuring security and privacy requirements are met.
- the development and maintenance of the security and privacy plans.
- ensuring that the system operates in accordance with the selected and implemented controls.
- deciding who has access to the system and with what types of privileges and access rights.
- ensuring system users and support personnel receive general and role-based training.
- the coordination and support of assessment and authorization activities including responding to assessment findings and assembling the authorization package.
- collaborating and cooperating with other RMF roles (e.g., security and privacy officers, information owner/steward, authorization official, control assessor, and others) on activities related to the above responsibilities.

(*) derived from [NIST Special Publication \(SP\) 800-37, Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy](#) (Appendix D, Roles and Responsibilities).

The system owner's understanding of the NIST risk management framework is essential to be successful in managing security and privacy risks for their system throughout the system's life cycle. The following are suggested initial preparatory activities for system owners including associated RMF resources to support such activities:

1. START: Where do I start?

- Review organizational policies for requirements and expectations as well as procedures, implementation guidance and organization-provided resources.
- Bookmark and explore the contents of the NIST Risk Management Framework (RMF) project web site: <https://nist.gov/rmf>.

2. LEARN: What do I need to know? What am I expected to do? What am I responsible for?

- Take the free online [RMF Introductory Courses](#) offered through the RMF web site. Available topics include RMF, SP 800-53, SP 800-53A and SP 800-53B. For those who are new to the RMF, we recommend taking the introductory course before reviewing NIST SP 800-37, the publication that describes the RMF (link below).
- Read [NIST Special Publication \(SP\) 800-37, Revision 2, Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy](#).
- Review the role and responsibilities of the system owner as described in Appendix D of NIST SP 800-37. Tip: review the responsibilities of other roles, especially those that interface with the system owner role.
- Know which roles the system owner collaborates with throughout the system life cycle. Tip: refer to the [RMF Roles and Responsibilities Crosswalk Quick Start Guide](#) for a summary of the system owner responsibilities at specific steps of the RMF.
- (Optional but recommended) review the [RMF Step FAQ Quick Start Guides](#) which answer commonly asked questions on each step of the RMF.

3. ADDITIONAL RESOURCES: Where can I find more information on available NIST resources?

- Review the [RMF Resources Quick Start Guide](#) for a listing of currently available RMF resources provided by NIST.
- Use and encourage system personnel to use the datasets, mappings/crosswalks and other implementer's resources provided by the [Cybersecurity and Privacy Reference Tool \(CPRT\)](#).
- Submit technical questions for the NIST RMF Team to sec-cert@nist.gov.

4. ENGAGE: What are other opportunities for collaboration, knowledge sharing?

- Subscribe to announce (email) lists [[RMF mailing list](#)] [[NIST mailing lists](#)]
- Follow NISTCyber on social media: [X](#), [Facebook](#), [LinkedIn](#), [Instagram](#), [YouTube](#), [Giphy](#), [RSS](#)
- Federal system owners are welcome to join the [Federal Cybersecurity and Privacy Professionals Forum](#), a NIST-sponsored platform for collaboration and knowledge sharing.
- Use the [SP 800-53 Public Comment Site](#) application to submit comments on the NIST SP 800-53 controls at any time and to preview upcoming changes to the controls.